Mainnet Safety & Security Guidelines

SatsPath is a powerful routing engine that coordinates interactions across multiple Bitcoin layers (Lightning, On-chain, and Ark). Moving real funds on Mainnet carries inherent risks. This document establishes the security perimeter for the engine.

1. Non-Custodial Architecture

SatsPath is NOT a custodial wallet. - The `Identity Key` (used to sign profiles) **does not** control funds. - Wallet, Node, or SDK plugins are responsible for securely managing funds and signing transactions. - Never store seed phrases, wallet private keys, macaroons, certs, API tokens, or other high-value secrets in the SatsPath repository or plaintext config files. - Email verification proves inbox access only. It does not transfer custody and does not prove ownership of a Gmail-style domain. - Receiver wallets must generate private keys locally on the receiver's device and publish only public payment profiles.

2. Mainnet Preview vs Mainnet Execution

Mainnet Preview

Mainnet Preview is allowed because it touches public data only:

- signed public payment profiles,
- public identity keys,
- public Lightning Address / LNURL metadata,
- BOLT11 invoice strings when explicitly requested,
- public on-chain addresses,
- BIP21 `bitcoin:` URIs,
- public Ark server and receiver pubkey pointers,
- route quotes and fee estimates,
- QR/payment pointer display.

Mainnet Preview does not move funds. It does not sign transactions, broadcast transactions, execute swaps, create/send Ark VTXOs, offboard/onboard, or touch wallet private keys.

Mainnet Execution

Mainnet execution is not implemented. No CLI flag exists for it. Any future mainnet execution feature must be a separate audited change with stronger confirmation gates and secret-storage controls.

The safe commands are preview commands:

```
satspath preview <recipient> <amount_sats> --mainnet
satspath preview <recipient> <amount_sats> --mainnet --json
satspath quote <recipient> <amount_sats> --mainnet-preview --json
```

`pay --mainnet-preview` is a preview screen only. It is not a payment sender.

3. Mainnet Configuration

By default, the SatsPath Swap Engine operates in **Testnet mode**.

Required Safety Defaults: - `mainnet_enabled = false` - `max_mainnet_payment_sats = 1000` - `require_manual_confirmation = true` - `fail_closed = true`

Mainnet preview is allowed because it touches public data only. Mainnet execution is disabled. `--experimental-swaps --testnet` is for testnet-only engine scaffolding; mainnet execution requires a separate future feature with stronger confirmation gates.

4. Strict Pre-Execution Checks

Before executing *any* Mainnet transaction or Swap, the engine MUST abort if any of the following checks fail: - **Amount Mismatch:** Abort if the requested invoice amount does not match the BOLT11 invoice returned by LNURL or Boltz. - **Signature Verification:** Abort if the `SignedPaymentProfile` signature is invalid or tampered with. - **Metadata Invalid:** Abort if LNURL metadata violates expected tags or amount bounds. - **Expiration:** Abort if the payment profile has expired.

5. First Mainnet Tests

When testing features on Mainnet for the first time: - Use tiny amounts only (e.g., `< 1000 sats`). - Verify routing paths locally before broadcasting. - Ensure that the local `.satspath/swaps.enc` vault is encrypting secrets via AES-GCM and not falling back silently to plaintext.

5. BIP-353 DNS Resolution (Mainnet Preview)

BIP-353 resolution is a **preview** layer: SatsPath resolves and displays DNSSEC-backed payment instructions but never pays, signs, or broadcasts.

- **DNSSEC is mandatory.** The default `Strict` policy fails closed and does not trust an upstream resolver's AD bit. `DevInsecure` mode is local-testing only, requires `--allow-insecure-dns-for-dev`, and prints a loud warning.
- **Ambiguity is invalid.** More than one `bitcoin:` TXT record at a name, or an unknown `req-*` parameter, makes resolution fail.
- **No private material** may ever appear in a published or resolved DNS payload (`seed`, `xprv/tprv`, `mnemonic`, `macaroon`, `cert`, `api_key`, `claim_key`, `refund_key`, `preimage`, …) — screened on both publish and resolve.
- **Record changes require an identity-key signature.** Email access alone never authorizes a DNS payment-instruction change.
- **Consumer email domains** (e.g. `gmail.com`) cannot use BIP-353; they fall back to platform verification / the invite flow.
- **DNS-provider credentials are never committed** — only a trait + mock publisher ship in this repo.